Information Security & Data Protection Policy

CATEGORY	Information Security | Cybersecurity Governance	EFFECTIVE DATE	January 1, 2026	REVIEW CYCLE	Annual Tata Corporate Audit

Article 1. Authentication Standards, Password Hygiene & Hardware MFA

1.1 Enterprise Password Complexity, 90-Day Rotation & Phishing-Resistant FIDO2

Information assets, customer intellectual property, proprietary source code, and enterprise cloud infrastructure represent the core lifeblood of Nexus Corporation. Compromised employee credentials represent the primary attack vector for enterprise security intrusions, ransomware deployment, and regulatory data breaches. All workforce members—including full-time employees, contractors, interns, and authorized vendors—must adhere strictly to enterprise authentication hygiene standards enforced through the Okta Identity Engine and corporate Active Directory / Google Workspace directory services.

All passwords for Nexus systems must be a minimum of 14 characters in length and incorporate at least one uppercase letter, one lowercase letter, one numeric digit, and one special character (!@#$%^&*). Passwords must be rotated every 90 calendar days. Password history filters prevent the reuse of any of the previous 6 passwords. Multi-factor authentication (MFA) is strictly mandatory on 100% of corporate logins. Authentication must utilize phishing-resistant methods: hardware FIDO2 tokens (Yubico YubiKey 5C) or Okta Verify Push with biometric verification. SMS-based and voice-call two-factor authentication are permanently banned.

Authentication Parameter	Corporate Technical Standard	Enforcement Mechanism	Prohibited Practice	Audit Frequency
Minimum Password Length	At least 14 characters (20+ for admin)	Active Directory & Okta complexity filter	Passwords < 14 chars; dictionary words	Automated real-time block
Password Expiration Cycle	Every 90 calendar days	Automated expiration notice via Okta	Disabling expiration; delaying changes	Daily automated directory scan
Password History Buffer	Cannot repeat previous 6 passwords	Cryptographic password history check	Alternating between two passwords	Enforced at directory level
Multi-Factor Authentication	Hardware FIDO2 YubiKey or Okta Push	Mandatory on all SSO logins and VPN	SMS 2FA; voice call; email verification	Continuous access telemetry
Privileged Account Access	20+ characters; separate admin account	CyberArk Privileged Access Management	Using standard user account for admin	Weekly privileged audit

- All corporate application passwords must be stored exclusively in 1Password, the enterprise password manager provisioned by IT.
- Sharing passwords, API keys, SSH private keys, or MFA push approvals with colleagues or supervisors is strictly forbidden.
- Employees receiving unsolicited MFA push notifications must reject them immediately and report suspicious activity to SOC.

PASSWORD SHARING ZERO-TOLERANCE MANDATE:
Sharing corporate passwords or approving unverified MFA push prompts is a critical security infraction resulting in immediate credential revocation, mandatory security retraining, and formal disciplinary warning placed in the personnel record.

Article 2. Workstation Security, Clean Desk Policy & Automatic Screen Locking

2.1 Clean Desk Standards, 5-Minute Inactivity Auto-Lock & Screen Privacy Filters

Physical and unattended workstation vulnerabilities provide opportunities for unauthorized visual eavesdropping, credential theft, and direct physical exfiltration of sensitive corporate and customer information. Nexus Corporation enforces a comprehensive Clean Desk and Clean Screen Policy across all physical office hubs, regional co-working facilities, and remote home working spaces. Whenever an employee steps away from their laptop or workstation—regardless of duration or location—they must manually lock their operating system screen immediately using standard system hotkeys (Windows: Win+L; macOS: Ctrl+Cmd+Q).

To safeguard against inadvertent oversights, all corporate-managed endpoints are centrally configured with an automated screen saver lock timeout that activates after 5 minutes of inactivity, requiring full biometric or password re-authentication to unlock. At the close of each working day, all physical desks must be cleared of printed confidential documents, customer files, access badges, and sensitive notes. All physical confidential records must be stored inside locked file cabinets or deposited into secure shredding bins.

Workstation Control	Mandatory Security Standard	Technical Implementation	Employee Daily Obligation	Compliance Verification
Manual Screen Lock	Immediate lock when stepping away	Hotkeys: Win+L (PC) / Ctrl+Cmd+Q (Mac)	Lock screen before leaving desk for any reason	Periodic physical floor audits
Automated Screen Timeout	5-Minute maximum inactivity timer	Centrally enforced via Jamf / Intune	Never attempt to disable or bypass with scripts	Automated compliance telemetry
Physical Clean Desk Policy	Zero documents / badges on desk overnight	Locking drawers; clean desk surface	Store all papers in locked pedestals daily	Nightly Facilities security sweep
Privacy Screen Filters	3M Privacy filter in public transit/airports	Directional light-blocking filter	Attach privacy filter when working in public	Mandatory for frequent travelers
Document Shredding Protocol	Cross-cut secure disposal bins only	Locked Iron Mountain shredding consoles	Deposit sensitive printouts into shred bins	Monthly shredding destruction cert

- Sticky notes containing passwords, system IP addresses, or PIN codes attached to monitors or keyboards are strictly prohibited.
- Employees working in public environments (coffee shops, airport lounges, trains) must angle screens away from public view.
- Nightly security sweeps conduct spot checks; unsecured sensitive materials are confiscated and logged as security infractions.

CLEAN DESK AUDIT SANCTIONS:
Leaving active workstations unlocked or confidential customer documents unattended is tracked by Corporate Security. Three clean desk violations within a 12-month period results in formal written reprimand and temporary suspension of remote work privileges.

Article 3. Removable Storage Devices, External Media Ban & USB Port Hardening

3.1 Enterprise USB Mass Storage Disablement, Cloud Whitelisting & Secure Data Transit

Removable storage media—including USB thumb drives, external hard drives, SD cards, and portable media players—represent severe vectors for data exfiltration, malware introduction, and catastrophic ransomware infection. In accordance with zero-trust architecture principles, Nexus Corporation enforces a total enterprise-wide technical ban on the connection of unauthorized removable mass storage devices to any corporate endpoint. Physical USB ports on all company-issued laptops and desktops are hardened and restricted.

USB mass storage capabilities are permanently disabled at the kernel and device driver level via CrowdStrike Falcon and Microsoft Intune device control policies. When an unauthorized USB mass storage drive is plugged into a corporate endpoint, the device is instantly blocked, an automated alert is dispatched to the Security Operations Center (SOC), and an incident ticket is generated. Data transfer to external cloud services is restricted exclusively to authorized enterprise-managed cloud repositories (Google Workspace).

Storage Channel	Corporate Policy Status	Technical Enforcement	Permitted Business Use Case	Exception Procedure
USB Thumb Drives / Flash Media	STRICTLY PROHIBITED & DISABLED	CrowdStrike endpoint device control block	None (100% blocked enterprise-wide)	No exceptions permitted
External USB Hard Drives	STRICTLY PROHIBITED & DISABLED	CrowdStrike endpoint device control block	None (Use corporate Google Drive)	No exceptions permitted
USB Input Peripherals (Mouse/Key)	PERMITTED (Human Interface Device)	HID class whitelisted; data channels blocked	Standard mice, keyboards, webcams, headsets	Plug-and-play standard peripherals
Corporate Google Drive	AUTHORIZED & ENCRYPTED	Google Workspace Enterprise DLP active	Primary corporate file storage & sharing	Standard corporate workflow
Personal Cloud Storage (Dropbox)	BLOCKED via Secure Web Gateway	Palo Alto Prisma Access URL filter block	Strictly prohibited for corporate files	Blocked by security proxy

- Connecting personal smartphones or tablets to corporate laptop USB ports for charging is discouraged to prevent accidental sync.
- Employees requiring large-scale data transfers with external clients must utilize secure, encrypted Box or Google Drive share links.
- Attempting to circumvent USB port restrictions using hardware dongles or driver exploits triggers immediate security suspension.

DATA EXFILTRATION MONITORING:
CrowdStrike endpoint sensors continuously monitor file activity. Any unauthorized attempt to copy source code, customer records, or confidential databases to external storage or unauthorized cloud accounts triggers automated account suspension and SOC escalation.

Article 4. Enterprise Data Classification Framework, Labeling & Encryption Controls

4.1 Four-Tier Data Classification Matrix, Cryptographic Standards & Automated DLP

To ensure that information assets receive protection commensurate with their sensitivity and potential harm from unauthorized disclosure, Nexus Corporation classifies all corporate data into four distinct tiers: (1) Public, (2) Internal, (3) Confidential, and (4) Restricted / PII. Every document, spreadsheet, database table, source code repository, and customer communication generated or processed by Nexus workforce members must be handled in accordance with the security controls mandated for its classification tier.

All data at rest stored across corporate laptops, mobile devices, database instances, and cloud buckets must be encrypted using industry-standard AES-256 encryption (FileVault on macOS; BitLocker on Windows; AWS KMS / GCP Cloud KMS for cloud workloads). All data in transit across internal and external networks must be encrypted using Transport Layer Security (TLS) 1.3 (or minimum TLS 1.2 with modern cipher suites). Automated Data Loss Prevention (DLP) engines inspect outbound email and Slack messages for sensitive data.

Classification Tier	Sensitivity Definition	Typical Data Assets	Access & Handling Standard	Encryption Mandate
Tier 1: Public	Information approved for public distribution	Marketing blogs, public press releases, job posts	No handling restrictions; open access	Standard web transport encryption
Tier 2: Internal	Internal operational information	Org charts, internal wikis, team meeting notes	Nexus workforce members only; no public sharing	Encrypted at rest & in transit
Tier 3: Confidential	Sensitive business & commercial data	Financial forecasts, product roadmaps, pricing models	Need-to-know access; NDA required for externals	AES-256 at rest; TLS 1.3 in transit
Tier 4: Restricted / PII	Highly sensitive customer PII & credentials	Customer PII, SSNs, credit cards, API secrets, code	Strict least-privilege RBAC; audit logged	Field-level encryption; tokenization
Source Code Repositories	Core proprietary intellectual property	Production GitHub repos, algorithmic codebases	Branch protection; signed commits; no export	AES-256; GitHub secret scanning

- Documents classified Confidential or Restricted must display classification watermarks in headers: 'CONFIDENTIAL - NEXUS CORP'.
- Customer Personally Identifiable Information (PII) must never be stored in development, testing, or staging environments.
- Production database exports containing real customer records are strictly prohibited without written authorization from the CPO and CISO.

DATA HANDLING MANDATE:
Exfiltrating, forwarding, or sharing Tier 3 (Confidential) or Tier 4 (Restricted) data to external personal email accounts, public paste sites, or unauthorized third parties is a federal offense and grounds for immediate termination with legal prosecution.

Article 5. Security Incident Response, Breach Notification & Phishing SLA

5.1 1-Hour SOC Incident Reporting SLA, 72-Hour Statutory Breach Notification & PhishAlarm

Rapid detection, containment, and transparent communication are critical to mitigating the impact of security incidents and satisfying stringent statutory regulatory obligations under GDPR Article 33, CCPA/CPRA, and state data breach notification laws. A Security Incident is defined as any verified or suspected event that compromises the confidentiality, integrity, or availability of Nexus corporate information assets, employee data, customer environments, or underlying cloud and physical infrastructure.

All workforce members are obligated to report any suspected security incident, lost corporate device, anomalous account activity, or potential compromise to the Security Operations Center (SOC) within 1 hour of discovery. Suspicious emails must be reported immediately via the 'PhishAlarm' button integrated into Google

Workspace and Outlook. The Nexus Incident Response Team executes a formal 4-phase incident response cycle: (1) Triage & Scoping, (2) Containment & Eradication, (3) Recovery, and (4) Post-Mortem.

Incident Severity Level	Severity Definition & Impact	Initial Triage SLA	Executive Escalation Path	External Regulatory SLA
Severity 1: Critical	Active enterprise breach, customer PII exposure, ransomware	Within 15 minutes by SOC	Immediate page: CISO, CEO, CLO, CFO	72-Hour statutory regulatory notice
Severity 2: High	Compromised credential, targeted spear-phishing attack	Within 30 minutes by SOC	Notification to CISO & Director of SecOps	Assessed by Legal within 24 hours
Severity 3: Medium	Lost encrypted laptop, policy non-compliance, malware alert	Within 2 hours by SOC	Security Operations Manager notification	Internal incident log entry only
Severity 4: Low	Generic spam/phishing campaign, unpatched workstation	Within 4 hours by SOC	Tier 1 SOC Analyst queue triage	Routine vulnerability tracking
PhishAlarm User Report	Employee-submitted suspicious email via button	Automated sandbox scan in 5m	SOC Analyst alert upon malicious verdict	Automated enterprise inbox sweep

- Nexus maintains a 72-hour statutory notification timeline to regulatory authorities under GDPR Article 33 for qualifying breaches.
- Employees must never attempt to perform forensic investigations personally or contact external authorities without Legal guidance.
- Post-incident reviews (PIR) are completed within 5 business days of incident closure to identify architectural improvements.

24/7/365 SECURITY HOTLINE:
Report suspected security incidents immediately via email to security@nexus-corp.internal or telephone the 24/7 Security Operations Center Hotline at +1-800-555-SOC1. Fast reporting minimizes damage and protects our entire customer community.

Article 6. Remote Network Security, Always-On VPN & Public Wi-Fi Restrictions

6.1 Palo Alto Prisma Access Architecture, Split-Tunneling Disablement & DNS Security

With the adoption of distributed hybrid and remote work models, corporate network perimeters have expanded beyond traditional physical office boundaries to encompass every endpoint connecting across global networks. To maintain zero-trust security postures, Nexus deploys the Palo Alto Prisma Access / GlobalProtect Cloud Security Platform across 100% of corporate endpoints. GlobalProtect is configured in an 'Always-On' posture that initiates an encrypted VPN tunnel automatically upon network connection detection.

Split-tunneling is strictly disabled enterprise-wide across all corporate VPN configurations. All network traffic—including internal cloud application traffic, enterprise SaaS tool access, and general internet browsing—routes through corporate next-generation firewalls (NGFW) for real-time TLS inspection, threat prevention, intrusion detection, and URL filtering. In public environments (airports, hotels, convention centers), connecting to unencrypted open Wi-Fi networks is prohibited without active GlobalProtect VPN.

Network Security Domain	Technical Configuration	Security Control Mandate	User Responsibility	Enforcement & Telemetry
Always-On Corporate VPN	Palo Alto GlobalProtect AES-256	Auto-connects upon network detection	Never attempt to disconnect or kill process	Automated connection failure alerts
Split-Tunneling Policy	Strictly DISABLED enterprise-wide	100% of internet traffic inspected	Accept full-tunnel inspection on work laptop	Firewall routing table validation
Public Wi-Fi Restrictions	Open / unencrypted Wi-Fi banned	Use cellular hotspot or secure WPA3	Connect to trusted networks; enable VPN	Rogue network detection in SOC
Secure DNS Resolution	Cisco Umbrella / Cloudflare Gateway	Blocks malicious command-and-control	All DNS queries route via corporate resolver	DNS query logging & inspection
Home Wi-Fi Encryption	WPA2-AES or WPA3 security standard	Change default router admin password	Update home router firmware annually	Annual remote security attestation

- Employees traveling internationally must confirm GlobalProtect gateway connectivity prior to departure for overseas destinations.
- Home Wi-Fi routers must be secured with WPA2-AES or WPA3 encryption; default administrative factory passwords must be changed.
- IoT smart devices (cameras, smart TVs, appliances) should be isolated on a separate guest network from corporate laptops.

PUBLIC WI-FI CAUTIONARY NOTICE:
Public Wi-Fi networks are vulnerable to man-in-the-middle (MitM) attacks, packet sniffing, and evil-twin rogue access points. Always verify that GlobalProtect displays a green 'Connected' status before typing passwords or accessing corporate systems.

Article 7. Secure Software Development Life Cycle (SSDLC), Code Review & Secrets Management

7.1 Shift-Left Security, Mandatory Peer Reviews & GitGuardian Automated Secret Scanning

Software engineering and cloud architecture at Nexus Corporation adhere to a rigorous Secure Software Development Life Cycle (SSDLC) framework based on NIST SP 800-218 and OWASP Top 10 standards. Security controls are integrated directly into development workflows ('Shift-Left Security') across all phases: architectural threat modeling, static code analysis, software composition analysis, peer code review, dynamic vulnerability scanning, and pre-deployment automated security regression gates.

All production software changes must undergo mandatory peer code review and receive at least one formal written approval from a designated code owner before merging into protected branches (main/production) within GitHub Enterprise. Committing sensitive secrets—including API keys, passwords, database connection strings, TLS certificates, or cloud access tokens—into git repositories is strictly forbidden. GitGuardian and GitHub Secret Scanning enforce pre-commit and push-protection hooks that block secret leaks.

SSDLC Security Gate	Tooling & Platform	Compliance Mandate	Verification Standard	Blocking Threshold
Secret Scanning & Leak Block	GitGuardian Enterprise & GitHub Secret	Pre-commit hooks + real-time push block	Zero committed secrets in any branch	Automated push rejection by GitHub
Static Analysis (SAST)	SonarQube Enterprise & Snyk Code	Automated scanning on every pull request	Zero Critical / High security vulnerabilities	PR merge blocked by quality gate

Software Composition (SCA)	Snyk Open Source & Dependabot	Scans dependencies for known CVEs	Zero CVEs with CVSS score >= 7.0	Automated PR created; merge blocked
Peer Code Review	GitHub Enterprise Protected Branches	Mandatory review by senior peer engineer	Verified architectural and security review	Branch rule prevents unreviewed PR
Dynamic Analysis (DAST)	OWASP ZAP & Burp Suite Enterprise	Automated staging environment penetration	Scans runtime APIs for injection flaws	Deployment pipeline halted on flaw

- Secrets must be managed exclusively through HashiCorp Vault or AWS Secrets Manager; hardcoded secrets are strictly prohibited.
- All git commits must be cryptographically signed using GPG or SSH commit signing keys registered in GitHub Enterprise.
- Open source libraries with copyleft licenses (GPL, AGPL) require prior approval from the Open Source Review Board (OSRB).

GITGUARDIAN SECRET LEAK SLA:
If an API key or credential is accidentally pushed to a git repository, GitGuardian alerts the SOC within 60 seconds. The secret is considered immediately compromised and must be revoked and rotated within 1 hour by the responsible development team.

Article 8. Cloud Infrastructure Security, Least-Privilege IAM & Posture Management

8.1 AWS & GCP Multi-Account Architecture, Wiz CSPM Monitoring & 90-Day Access Recertification

Nexus Corporation cloud infrastructure hosted on Amazon Web Services (AWS) and Google Cloud Platform (GCP) is architected according to the principle of least privilege, zero-trust network segmentation, and Infrastructure as Code (IaC) governance. Cloud access is provisioned through central Identity and Access Management (IAM) integrated with Okta Single Sign-On. Long-lived static cloud credentials (AWS Access Keys) are prohibited for human users, who must authenticate using temporary short-lived STS tokens.

Wiz Cloud Security Posture Management (CSPM) and Cloud Infrastructure Entitlement Management (CIEM) tools continuously monitor all cloud production environments for misconfigurations, publicly exposed S3 buckets, overly permissive IAM roles, and toxic risk combinations. All production infrastructure must be provisioned via Terraform through automated CI/CD pipelines; manual configuration changes in production cloud consoles ('ClickOps') are strictly prohibited and trigger automated SOC investigation alerts.

Cloud Security Control	Technology Platform	Operating Standard	Review / Enforcement Cycle	Accountability Role
Least-Privilege Cloud IAM	AWS IAM Identity Center / GCP IAM	Temporary STS tokens; zero static keys	Continuous entitlement rightsizing	Cloud Infrastructure Team
Cloud Security Posture (CSPM)	Wiz Cloud Security Platform	Continuous misconfiguration scanning	Real-time automated vulnerability alerts	Security Architecture Team
Infrastructure as Code (IaC)	Terraform Enterprise & Checkov	100% of infra provisioned via code	Automated security scanning on PRs	DevOps & Cloud Engineering
Cloud Audit Logging	AWS CloudTrail & GCP Cloud Audit	Immutable multi-region log aggregation	Retained 365 days in secure bucket	SOC Forensics & SIEM Team
IAM Access Recertification	Okta Identity Governance (OIG)	Recertification of all production roles	Mandatory quarterly review (90 days)	Department Directors & Managers

- Production cloud environments are logically and physically separated from development and staging environments.
- Cloud storage buckets (AWS S3, Google Cloud Storage) are configured with public access blocks permanently enabled by default.
- Quarterly access recertifications require managers to re-authorize employee production access; unconfirmed access is auto-revoked.

PRODUCTION 'CLICKOPS' BAN:
Making direct, unversioned configuration changes in production cloud consoles is strictly prohibited. All changes must be codified in Terraform, reviewed by peers, scanned for security misconfigurations, and deployed through the automated CI/CD pipeline.

Article 9. Third-Party Vendor Security Risk Management & Data Processing Agreements

9.1 Vendor Risk Tiering, SOC 2 Type II Mandate & Annual Security Re-Assessments

Third-party software-as-a-service (SaaS) providers, cloud platforms, and professional service vendors represent critical components of our operational ecosystem, but also introduce third-party supply chain risks. Prior to executing any contract, purchasing software, or sharing corporate or customer data with an external vendor, the vendor must undergo formal Third-Party Risk Assessment (TPRA) conducted by the Information Security Risk Team and approved by Legal Counsel in accordance with corporate procurement governance.

All vendors processing Confidential or Restricted corporate data must provide an annual independent SOC 2 Type II examination report covering the Security, Confidentiality, and Availability Trust Services Criteria with an unqualified auditor opinion. In addition, vendors must execute the Nexus Data Processing Agreement (DPA) incorporating Standard Contractual Clauses (SCCs) for cross-border data transfers, mandatory 48-hour breach notification covenants, and full audit rights. Vendor assessments are renewed annually.

Vendor Risk Tier	Data Access Scope	Mandatory Security Prerequisites	Approval Authority	Re-Assessment Cycle
Tier 1: Critical Vendor	Access to production data, PII, source code	SOC 2 Type II, SIG Full, ISO 27001, DPA	CISO & General Counsel approval	Annual comprehensive audit
Tier 2: Significant Vendor	Access to internal operational business data	SOC 2 Type II (or ISO 27001), SIG Lite, DPA	Director of Information Security	Annual automated risk review
Tier 3: Low-Risk Vendor	Zero access to confidential data or systems	Vendor security questionnaire, privacy review	Procurement & Security Manager	Biannual risk re-assessment
Open Source Tooling	Developer libraries, CLI tools, frameworks	OSRB licensing review, Snyk vulnerability check	Open Source Review Board Lead	Continuous dependency scanning
Shadow IT Software	Unapproved SaaS tools adopted by staff	STRICTLY PROHIBITED enterprise-wide	Blocked via Netskope Cloud CASB	Immediate account suspension

- Procuring SaaS applications using personal credit cards or departmental expense accounts without Security approval is banned.
- Netskope Cloud Access Security Broker (CASB) continuously monitors web traffic to detect and block unsanctioned Shadow IT tools.
- Vendors failing annual security assessments are given 60 days to remediate deficiencies or face contractual termination.

SHADOW IT SOFTWARE BAN:
Inputting company source code, client records, or internal roadmaps into unsanctioned third-party AI tools (e.g., consumer ChatGPT) is a critical security violation. Workforce members must use only enterprise-provisioned, contractually protected AI platforms.

Article 10. Physical Facility Security, Badge Access & Visitor Escort Protocols

10.1 Keycard Access Control, Anti-Tailgating Rules & 90-Day CCTV Video Retention

Physical facility security is the first line of defense protecting corporate assets, enterprise datacenters, and personnel. All Nexus facilities—including global headquarters, regional development hubs, and testing laboratories—operate centralized electronic access control systems utilizing encrypted RFID smart badges. All employees, contractors, and interns must wear their company-issued photo identification badges visibly above the waist at all times while present on corporate property or within facility perimeters.

Tailgating—the practice of holding doors open for colleagues or allowing un-badged individuals to follow an authorized employee through secure entry turnstiles or doors—is strictly prohibited under corporate security rules. Every person entering a facility must tap their individual badge. Visitors, vendors, and clients must register at the reception desk, present valid government photo identification, execute a Non-Disclosure Agreement (NDA), and be escorted by an authorized Nexus employee throughout their visit.

Facility Security Control	Operating Standard	Enforcement Mechanism	Prohibited Activity	Retention & Audit SLA
Photo ID Badge Display	Worn visibly above the waist at all times	Security guard and receptionist visual checks	Concealing badge; leaving badge at home	Continuous floor enforcement
Electronic Turnstiles	One badge swipe per person (No tailgating)	Optical anti-tailgating sensors & alarms	Holding turnstiles; piggybacking entries	Turnstile access log retention: 365d
Visitor Management	Sign in at reception; photo ID; sign NDA	Envoy visitor management tablet portal	Unescorted visitors in engineering areas	Visitor log retention: 3 years
Server Room Access	Restricted to authorized infrastructure staff	Biometric fingerprint + dual keycard swipe	Loitering; propping open server room doors	Access log reviewed monthly
CCTV Security Surveillance	24/7 Monitoring of entrances, server rooms	High-definition motion-activated cameras	Tampering with cameras; blocking views	Video retention: 90 calendar days

- Lost or stolen access badges must be reported immediately to Facilities Security to deactivate credentials instantly.
- Temporary one-day badges issued by reception expire automatically at 11:59 PM on the date of issuance.
- Facility CCTV video footage is securely retained for 90 days and reviewed exclusively for authorized security investigations.

ANTI-TAILGATING ENFORCEMENT:
Do not hold security doors open for anyone, even familiar colleagues. Politely ask individuals to tap their own badges or report to reception. Permitting an un-badged intruder to enter a facility is grounds for formal disciplinary counseling.

Article 11. Continuous Security Audits, Threat Hunting, SIEM Telemetry & Enforcement

11.1 Splunk SIEM Telemetry, Quarterly Penetration Testing & Disciplinary Penalties

Security assurance at Nexus Corporation is an active, continuous operational discipline rather than an annual compliance checklist. All network firewalls, cloud infrastructure, identity providers, endpoint sensors, and application services stream real-time telemetry into our central Splunk Security Information and Event Management (SIEM) cluster. The Security Operations Center (SOC) operates 24/7/365, conducting automated threat correlation, heuristic behavioral anomaly detection, and active threat hunting across all logs.

To rigorously validate defensive resilience, Nexus engages accredited third-party cybersecurity firms to conduct Quarterly External Penetration Tests, API security assessments, and annual red-team adversary emulation exercises. Critical vulnerabilities discovered during penetration testing must be remediated within 7 calendar days; high vulnerabilities must be remediated within 14 calendar days. Violations of information security standards result in progressive disciplinary sanctions up to summary termination of employment.

Security Assurance Area	Testing / Auditing Mechanism	Frequency / Cycle	Remediation SLA	Governance & Reporting
SIEM Log Aggregation	Splunk Enterprise SIEM multi-region cluster	Continuous real-time log ingestion (24/7)	Real-time automated threat correlation	SOC Analyst Tier 1/2/3 queue
External Penetration Testing	CREST-accredited external red team	Quarterly comprehensive assessments	Critical: 7 days; High: 14 days; Med: 30d	Reported to Board Audit Committee
Vulnerability Management	Qualys & Tenable continuous agent scans	Weekly vulnerability scan cycle	Zero critical CVEs past 7 days SLA	Weekly vulnerability dashboard to CISO
Red-Team Adversary Sim	Simulated advanced persistent threat (APT)	Annual blind adversary simulation	Security architecture enhancements	Executive Leadership briefing
Disciplinary Sanctions	Progressive discipline framework	Immediate upon substantiated breach	Formal personnel file documentation	VP People Ops & Legal review

- All security telemetry logs are cryptographically hashed and retained in immutable storage for a minimum of 365 calendar days.
- Employees are required to complete mandatory annual security awareness training and quarterly simulated phishing tests.
- Employees failing three consecutive simulated phishing tests are required to complete remedial 1-on-1 cybersecurity coaching.

SECURITY POLICY VIOLATION PENALTIES:
Willful violations of information security policies—including disabling security agents, sharing credentials, exfiltrating data, or introducing unauthorized code—will result in immediate termination for cause, civil litigation, and criminal law enforcement referral.

Article 12. Regulatory Compliance, ISO 27001 / SOC 2 Governance & Executive Ratification

12.1 Regulatory Certification Alignment, Annual Third-Party Attestation & Governance

Nexus Corporation maintains rigorous alignment with global cybersecurity and data privacy regulatory standards. Our Information Security Management System (ISMS) is certified annually under ISO/IEC 27001:2022 standards and audited under the AICPA SOC 2 Type II framework across all five Trust Services Criteria (Security, Availability, Processing Integrity, Confidentiality, and Privacy). In addition, our data processing activities comply with GDPR (EU), UK Data Protection Act, CCPA/CPRA (California), and HIPAA.

The Information Security Governance Committee—comprising the Chief Information Security Officer (CISO), Chief Legal Officer (CLO), Chief Technology Officer (CTO), and Chief People Officer (CPO)—convenes quarterly to review emerging threat landscapes, audit findings, policy revisions, and compliance metrics. This policy is reviewed, updated, and re-ratified annually to reflect evolving regulatory mandates and architectural advancements, establishing binding operational standards for all Nexus workforce members globally.

Regulatory Framework	Certifying Body / Standard	Certification Scope	Audit Frequency	Customer Attestation Deliverable
ISO/IEC 27001:2022	BSI Group Accredited Registrar	Enterprise-wide ISMS scope	Annual surveillance / 3-year recert	ISO 27001 Certificate of Registration
SOC 2 Type II Examination	Big Four Independent CPA Audit Firm	All 5 Trust Services Criteria	Annual continuous 12-month period	SOC 2 Type II Formal Examination Report
GDPR / UK Data Protection	Data Protection Authority Alignment	Global customer and employee PII	Continuous compliance monitoring	Data Protection Impact Assessments (DPIA)
California CCPA / CPRA	California Privacy Protection Agency	California consumer & employee privacy	Annual privacy compliance review	Annual Consumer Privacy Policy update
HIPAA Security Rule	Independent Healthcare Security Auditor	Protected Health Information (PHI) in HR	Biannual HIPAA security audit	HIPAA Compliance Attestation Letter

- Customers and authorized enterprise partners may request official SOC 2 Type II reports through the Nexus Trust Center portal.
- Nexus maintains comprehensive cyber liability insurance coverage ($20,000,000 aggregate policy) through Lloyd's of London.
- This policy supersedes all prior information security guidelines, departmental IT policies, and informal working agreements.

EXECUTIVE RATIFICATION & APPROVAL:
This policy has been formally ratified by the Chief Information Security Officer, General Counsel, and Chief People Officer of Nexus Corporation effective January 1, 2026, establishing mandatory operating standards across all corporate divisions and subsidiaries.

Document Governance, Audit History & Tata Code of Conduct Authorization

Revision	Release Date	Author / Department	Summary of Regulatory Changes
v1.0	Jan 15, 2024	TCS Global HR Taskforce	Initial codification of associate policies aligned with Tata Code of Conduct (TCoC) and statutory labor standards.
v2.0	Nov 10, 2024	Corporate Ethics & Compliance	Updated statutory maternity/paternity protections, POSH ICC inquiry guidelines, and bereavement leave rules.
v3.0	Jan 01, 2025	TCS Total Rewards Council	Bouquet of Benefits (BoB) tax optimization, NPS corporate Tier 1 integration, and TCS Health Insurance Scheme (TCS-HIS) enhancement.
v4.0	Oct 15, 2025	Delivery Operations & Workplace	Codified 5-day return-to-office (RTO) attendance linkage with quarterly performance pay (QPP) and Secure Borderless Workspaces (SBWS).
v6.0	Jan 01, 2026	Chief Human Resources Officer & Legal	Annual consolidation. ISO 27001 ISMS controls, Generative AI acceptable usage governance, and Ultimatix ESS automation.

Signatory Role	Authorized Representative	Approval Status	Digital Signature Hash
Chief Human Resources Officer (CHRO)	Milind Lakkad	APPROVED & RATIFIED	SHA256: 7f8a9b2c3d4e5f6a7b8c9d0e1f2a3b4c5d6e7f8a...tcs001
General Counsel & Ethics Officer	S. Venkataramanan, Esq.	COMPLIANCE VERIFIED	SHA256: 9b2c3d4e5f6a7b8c9d0e1f2a3b4c5d6e7f8a9b0c...tcs002
Chief Financial Officer (CFO)	Samir Seksaria, FCA	FISCAL BUDGET RATIFIED	SHA256: 3d4e5f6a7b8c9d0e1f2a3b4c5d6e7f8a9b0c1d2e...tcs003
Global Head - Delivery Excellence	K. Ananth Krishnan	GOVERNANCE CERTIFIED	SHA256: 5f6a7b8c9d0e1f2a3b4c5d6e7f8a9b0c1d2e3f4a...tcs004

Statutory Disclosure: This official regulatory document constitutes binding corporate policy for Tata Consultancy Services Limited and all global subsidiaries. Inquiries regarding statutory interpretation, policy exceptions, or Ultimatix regularizations must be logged via the Ultimatix Global Helpdesk within 5 business days. Unauthorized reproduction or distribution outside authorized associate channels is strictly prohibited under Tata Code of Conduct (TCoC). This document supersedes all prior versions.